COURS DE CYBERSÉCURITÉ & CONFORMITÉ

RGPD : obligations, droits des personnes et violations de données
Séances 4 et 5 — 4 heures de formation

TABLE DES MATIÈRES

Objectifs pédagogiques 2

Vue d'ensemble des deux séances 2

Séance 4 — Obligations RGPD (2 heures) 2

Partie 1 — Les acteurs et leurs responsabilités 2
1.1. Qu'est-ce qu'une donnée personnelle et un traitement ? 2
1.2. Les acteurs à distinguer 3
1.3. Exemple : fuite chez un hébergeur + Exercice 1 3
Partie 2 — Le registre des activités de traitement 3
2.1. À quoi sert le registre ? 3
2.2. Contenu essentiel d'une fiche de registre 4
2.3. Exemple de fiche simplifiée + Exercice 2 4
Partie 3 — Bases légales et consentement 4
3.1. Pourquoi une base légale ? 4
3.2. Les quatre critères du consentement 5
3.3. Exemples de consentement valide ou invalide + Exercice 3 5
Partie 4 — Synthèse de la séance 4 5

Séance 5 — Droits des personnes et notification de violation 6

Partie 1 — Les droits des personnes 6
1.1. Principes de traitement d'une demande 6
1.2. Les quatre droits à connaître pour l'examen 6
1.3. Schéma de traitement d'une demande + Exercice 4 6
Partie 2 — Violation de données personnelles 7
2.1. Définition et catégories 7
2.2. Les premières actions opérationnelles 7
2.3. La règle des 72 heures 7
2.4. Faut-il informer les personnes ? 7
2.5. Schéma décisionnel à mémoriser 7
Partie 3 — Contenu d'une fiche de notification 8
Livrable — Fiche type de notification de violation 8

Cas pratiques — format examen (Cas 1 à 4) 10

Mini-évaluation (10 questions) 10

Fiche mémo — les erreurs fréquentes à l'examen 11

Références officielles pour approfondir 11

Lexique des termes essentiels 12

FAQ — Questions fréquentes 14

Document enrichi : table des matières • lexique • FAQ ajoutés sans modification du contenu original des séances 4 et 5.
Niveau conseillé : BTS / formation professionnelle en informatique, cybersécurité ou conformité. Référence principale : règlement (UE) 2016/679 (RGPD).

COURS DE CYBERSÉCURITÉ & CONFORMITÉ

RGPD : obligations, droits des personnes et violations de données

Séances 4 et 5 — 4 heures de formation

Support apprenant • Schémas • Cas pratiques corrigés • Fiche type de notification

Séance	Durée	Compétences principales
4 — Obligations RGPD	2 h	Acteurs, registre, consentement et bases légales
5 — Droits et violations	2 h	Droits des personnes, qualification d'une violation, CNIL et information des personnes

Niveau conseillé : BTS / formation professionnelle en informatique, cybersécurité ou conformité.

Référence principale : règlement (UE) 2016/679 (RGPD), notamment articles 4 à 7, 12 à 22, 28 à 30, 32 à 34.

Note pédagogique : ce support présente les principes généraux. Pour une situation réelle, il faut examiner les faits, les textes applicables et les recommandations à jour de la CNIL.

Objectifs pédagogiques

- Distinguer responsable de traitement, sous-traitant, responsable conjoint et DPO.
- Expliquer l'utilité du registre et remplir une fiche de traitement simple.
- Choisir et justifier une base légale parmi les six bases prévues par l'article 6.
- Reconnaître les conditions d'un consentement valide.
- Expliquer les droits d'accès, de rectification, d'effacement et de portabilité.
- Qualifier une violation de données et appliquer les règles de documentation, de notification et de communication.
- Rédiger une fiche de notification contenant les informations utiles, sans inventer les éléments inconnus.

Vue d'ensemble des deux séances

Séance	Déroulé indicatif
Séance 4 — 120 min	10 min : rappel des notions • 30 min : acteurs • 25 min : registre • 35 min : bases légales et consentement • 20 min : exercice corrigé
Séance 5 — 120 min	10 min : rappel • 30 min : droits • 35 min : violation et délais • 25 min : cas pratiques • 20 min : fiche de notification et synthèse

Séance 4 — Obligations RGPD (2 heures)

Partie 1 — Les acteurs et leurs responsabilités (30 min)

1.1. Qu'est-ce qu'une donnée personnelle et un traitement ?

Une donnée personnelle est toute information se rapportant à une personne physique identifiée ou identifiable. Le nom, l'adresse électronique nominative, l'identifiant d'un compte, certaines adresses IP, les données de localisation et les données de santé peuvent être des données personnelles selon le contexte.

Un traitement est une opération ou un ensemble d'opérations appliquées à des données : collecte, enregistrement, classement, consultation, transmission, modification, conservation ou suppression. Il peut être numérique, sur papier ou hybride.

Exemples : gérer les candidatures, établir les fiches de paie, administrer les comptes informatiques, envoyer une newsletter, gérer les dossiers de patients ou enregistrer les visiteurs.

1.2. Les acteurs à distinguer

Acteur	Rôle	Exemple
Responsable de traitement	Détermine les finalités (pourquoi) et les moyens essentiels (comment) du traitement.	Une école choisit de collecter les coordonnées des étudiants pour gérer les inscriptions.
Sous-traitant	Traite des données pour le compte du responsable, selon ses instructions documentées.	Un prestataire héberge la plateforme d'inscription.
DPO / délégué à la protection des données	Informe, conseille, sensibilise, contrôle la conformité et sert de point de contact avec l'autorité.	Le DPO conseille sur les durées de conservation et suit les demandes de droits.
Responsables conjoints	Déterminent ensemble les finalités et les moyens essentiels d'un traitement.	Deux organismes conçoivent ensemble une campagne et décident des données à collecter.

Schéma à mémoriser :

Décide du pourquoi et des moyens essentiels	Exécute pour le compte du responsable	Conseil, contrôle et point de contact
Responsable de traitement	Sous-traitant	DPO

Le DPO ne remplace pas la direction et n'endosse pas automatiquement toute la responsabilité juridique. Sa désignation est obligatoire dans les cas prévus à l'article 37 : notamment certaines autorités publiques, certaines activités de suivi régulier et systématique à grande échelle et certains traitements à grande échelle de données sensibles.

1.3. Exemple : fuite chez un hébergeur

Une entreprise confie l'hébergement de sa base clients à un prestataire. Une mauvaise configuration rend la base accessible publiquement.

- L'entreprise est généralement responsable du traitement si elle a déterminé les finalités et les moyens essentiels.
- L'hébergeur est sous-traitant s'il agit uniquement sur instructions documentées.
- Les équipes techniques doivent contenir l'exposition, préserver les éléments utiles à l'enquête et déterminer les données concernées.
- Le DPO, s'il existe, conseille et surveille la conformité ; la décision de notification relève du responsable de traitement.
- Le contrat doit encadrer la sécurité, la confidentialité, l'assistance et la transmission rapide des informations en cas de violation.

Attention : si un sous-traitant décide lui-même des finalités et des moyens essentiels, il peut être considéré comme responsable de traitement pour ce traitement.

Exercice 1 — Identifier les rôles

Une clinique choisit les données collectées et leurs usages médicaux. Un prestataire héberge le logiciel selon ses instructions. Une personne indépendante est formellement désignée DPO.

Questions : qui est responsable de traitement ? Quel est le rôle du prestataire ? Que fait le DPO ? Qui décide des finalités ?

Correction : la clinique est responsable de traitement ; le prestataire est sous-traitant dans le scénario décrit ; le DPO conseille, sensibilise et contrôle avec indépendance ; les finalités sont déterminées par la clinique.

Partie 2 — Le registre des activités de traitement (25 min)

2.1. À quoi sert le registre ?

Le registre, prévu par l'article 30, donne une vue structurée des traitements mis en œuvre. Il aide à savoir quelles données sont utilisées, pour quelles raisons, par qui, pendant combien de temps et avec quelles protections. C'est un outil de pilotage et de preuve de conformité, pas une simple liste de logiciels.

Le registre doit refléter la réalité et être mis à jour lors des changements : nouvelle finalité, nouvelle catégorie de données, nouveau destinataire, changement de durée de conservation ou nouvelle mesure de sécurité.

2.2. Contenu essentiel d’une fiche de registre

- Identité et coordonnées du responsable de traitement et, le cas échéant, du DPO et des responsables conjoints.
- Finalités du traitement.
- Catégories de personnes concernées : clients, salariés, candidats, élèves, patients, etc.
- Catégories de données : identité, coordonnées, données RH, données de connexion, données sensibles, etc.
- Catégories de destinataires, y compris les sous-traitants et, le cas échéant, les destinataires dans des pays tiers.
- Transferts hors de l’Espace économique européen, le cas échéant, et garanties associées.
- Délais prévus d’effacement ou critères permettant de les déterminer.
- Description générale des mesures de sécurité techniques et organisationnelles.

Le RGPD prévoit une exception limitée à l’obligation de registre pour certaines organisations de moins de 250 salariés, mais elle ne s’applique pas lorsque les traitements présentent les caractéristiques visées par l’article 30(5), notamment s’ils ne sont pas occasionnels, comportent des risques ou portent sur certaines données sensibles ou relatives aux condamnations et infractions. En pratique, une petite structure doit donc vérifier ses traitements plutôt que supposer qu’elle est exemptée.

2.3. Exemple de fiche simplifiée

Champ	Exemple : gestion des candidatures
Finalité	Recevoir, examiner et suivre les candidatures à un emploi.
Personnes concernées	Candidats et personnes de référence, si applicable.
Données	Identité, coordonnées, CV, lettre de motivation, échanges liés au recrutement.
Base légale	À déterminer selon les opérations : mesures précontractuelles demandées par le candidat et/ou intérêt légitime, après analyse.
Destinataires	RH et managers habilités ; prestataire de recrutement si nécessaire.
Conservation	Durée définie et justifiée selon les étapes du recrutement et les obligations applicables.
Sécurité	Accès limité, authentification, journalisation pertinente, sauvegardes et suppression contrôlée.

Méthode : recenser les activités par finalité, et non par nom du logiciel. Un même logiciel peut servir à plusieurs traitements ; inversement, une finalité peut mobiliser plusieurs outils.

Exercice 2 — Repérer les oublis

Un registre indique uniquement : « Logiciel RH — données salariés — accès RH ». Citez quatre informations à compléter.

Correction possible : finalités précises, catégories de données, destinataires, base légale documentée dans le dossier de conformité, durée de conservation, sous-traitants, transferts éventuels et mesures générales de sécurité.

Partie 3 — Bases légales et consentement (35 min)

3.1. Pourquoi une base légale ?

Avant de commencer un traitement, le responsable doit identifier un fondement juridique applicable à chaque finalité. Le consentement n’est pas systématiquement obligatoire. La base choisie doit correspondre à la réalité du traitement et être expliquée aux personnes.

Base légale (art. 6)	Quand peut-elle s’appliquer ?	Exemple indicatif
Consentement	La personne accepte librement, spécifiquement, de façon éclairée et par un acte positif clair.	Inscription volontaire à une newsletter lorsque cette base est retenue.
Contrat / mesures précontractuelles	Le traitement est nécessaire à l’exécution du contrat ou à des démarches demandées avant sa conclusion.	Utiliser l’adresse de livraison pour expédier une commande.
Obligation légale	Une règle impose au responsable de réaliser le traitement.	Conserver certains documents comptables selon les textes applicables.

Base légale (art. 6)	Quand peut-elle s'appliquer ?	Exemple indicatif
Intérêts vitaux	Nécessaire pour protéger les intérêts vitaux d'une personne physique.	Situation d'urgence grave où la personne ne peut pas donner son accord.
Mission d'intérêt public / autorité publique	Nécessaire à une mission fondée sur le droit applicable.	Traitement effectué par un organisme investi d'une mission publique.
Intérêts légitimes	Intérêt légitime du responsable ou d'un tiers, après mise en balance avec les droits et libertés des personnes.	Certaines mesures de sécurité ou activités internes, selon le contexte.

Le tableau donne des exemples, pas des automatismes : le responsable doit vérifier la nécessité, la proportionnalité, les textes applicables et les attentes raisonnables des personnes. Les intérêts légitimes ne sont pas la base appropriée pour l'exercice des missions des autorités publiques dans l'exécution de leurs missions.

3.2. Les quatre critères du consentement

- Libre : la personne dispose d'un véritable choix, sans pression indue ni désavantage injustifié en cas de refus.
- Spécifique : le choix porte sur une finalité déterminée ; un accord général et vague ne suffit pas.
- Éclairé : la personne reçoit une information compréhensible sur le traitement concerné.
- Univoque : une action positive claire manifeste l'accord. Le silence, l'inaction ou une case précochée ne suffisent pas.

Le responsable doit pouvoir prouver le consentement. La personne peut le retirer à tout moment, et le retrait doit être aussi simple que l'accord. Le retrait n'annule pas rétroactivement la licéité des opérations réalisées avant celui-ci.

3.3. Exemples de consentement valide ou invalide

Situation	Analyse
Case newsletter non cochée par défaut, libellé clair, choix distinct.	Peut constituer un consentement valable si les autres conditions sont respectées.
Case « J'accepte tout » précochée.	Ne constitue pas un consentement valide.
Refus de publicité empêchant l'accès à un service sans justification valable.	Le caractère libre du consentement peut être contesté.
Adresse utilisée pour exécuter une commande.	Le contrat peut être la base appropriée ; un consentement n'est pas nécessairement requis pour cette finalité.
Conservation de documents imposée par une loi.	L'obligation légale peut être la base appropriée, et non le consentement.

Exercice 3 — Choisir la base

Pour chaque situation, proposez une base légale à vérifier et justifiez-la : (A) expédier une commande ; (B) conserver une facture lorsque la loi l'impose ; (C) envoyer une newsletter facultative ; (D) gérer une demande d'emploi.

Correction indicative : A contrat ; B obligation légale ; C consentement lorsque requis et retenu pour cette finalité ; D mesures précontractuelles à la demande du candidat et/ou intérêt légitime selon l'opération et le contexte. Il faut distinguer les finalités d'un même service.

Partie 4 — Synthèse de la séance 4 (10 min)

- Le responsable détermine les finalités et les moyens essentiels.
- Le sous-traitant agit pour le compte du responsable et selon ses instructions documentées.
- Le DPO conseille et contrôle avec indépendance ; il ne remplace pas la direction.
- Le registre décrit les traitements et doit être tenu à jour.
- Chaque finalité doit reposer sur une base légale pertinente.
- Le consentement est une base parmi six et doit être libre, spécifique, éclairé et univoque.

Séance 5 — Droits des personnes et notification de violation (2 heures)

Partie 1 — Les droits des personnes (30 min)

1.1. Principes de traitement d'une demande

Une personne peut exercer ses droits auprès de l'organisme qui traite ses données. L'organisme doit organiser un circuit de réception, de vérification proportionnée de l'identité lorsque nécessaire, de recherche, de réponse et de traçabilité. Une demande reçue par un collaborateur doit être transmise au bon interlocuteur sans retard.

En règle générale, le responsable répond dans un délai d'un mois à compter de la réception. Ce délai peut être prolongé de deux mois supplémentaires si nécessaire, compte tenu de la complexité ou du nombre de demandes ; la personne doit être informée de la prolongation et de ses motifs dans le délai initial. En cas de doute raisonnable sur l'identité, des informations supplémentaires nécessaires peuvent être demandées.

1.2. Les quatre droits à connaître pour l'examen

Droit	Ce que la personne peut demander	Limites / points de vigilance
Accès (art. 15)	Confirmer si ses données sont traitées, en obtenir une copie et recevoir des informations sur le traitement.	Protéger les droits et libertés d'autrui ; la réponse ne se limite pas toujours à exporter une base brute.
Rectification (art. 16)	Corriger des données inexactes ou compléter des données incomplètes.	Vérifier la demande et corriger les systèmes pertinents.
Effacement (art. 17)	Obtenir l'effacement dans les situations prévues, par exemple si les données ne sont plus nécessaires ou si le consentement est retiré sans autre base.	Le droit n'est pas absolu : certaines obligations légales, la liberté d'expression, des motifs d'intérêt public ou la défense de droits en justice peuvent justifier une conservation.
Portabilité (art. 20)	Recevoir certaines données fournies par la personne, dans un format structuré, couramment utilisé et lisible par machine, et les transmettre à un autre responsable.	S'applique notamment lorsque le traitement est automatisé et fondé sur le consentement ou le contrat. Ne couvre pas indistinctement toutes les données et tous les traitements.

1.3. Schéma de traitement d'une demande

1. Recevoir	2. Vérifier	3. Rechercher	4. Répondre	5. Tracer
Enregistrer la date et la demande	Vérification proportionnée si nécessaire	Interroger les systèmes et services concernés	Réponse claire dans le délai applicable	Conserver la preuve du traitement de la demande

Exercice 4 — Droit d'effacement

Un ancien client demande la suppression de toutes ses données. L'entreprise doit conserver certaines factures en vertu d'une obligation légale. Que doit-elle faire ?

Correction : examiner les données et finalités séparément, supprimer celles qui n'ont plus de justification, conserver uniquement les données nécessaires à l'obligation applicable pendant la durée requise, expliquer les limites à la personne et limiter les accès aux données conservées. Il ne faut ni promettre un effacement total impossible, ni refuser globalement sans analyse.

Partie 2 — Violation de données personnelles (35 min)

2.1. Définition et catégories

Selon l'article 4(12), une violation de données personnelles est une violation de sécurité entraînant, accidentellement ou illicitement, la destruction, la perte, l'altération, la divulgation non autorisée de données personnelles ou l'accès non autorisé à celles-ci.

Type	Exemple
Confidentialité	Un courriel contenant des données RH est envoyé au mauvais destinataire ; une base est accessible publiquement.
Intégrité	Un attaquant modifie des coordonnées bancaires ou des dossiers.

Type	Exemple
Disponibilité	Un incident rend des dossiers personnels indisponibles ou les détruit.

Une violation ne signifie pas nécessairement qu'il y a eu piratage. Une erreur humaine, une perte de support ou un envoi au mauvais destinataire peuvent aussi constituer une violation.

2.2. Les premières actions opérationnelles

Détecter et signaler rapidement l'incident au point de contact interne.

Contenir l'incident : fermer l'accès exposé, désactiver un compte compromis ou isoler un système, en préservant autant que possible les preuves.

Établir les faits : données, personnes, période, cause probable, accès ou exfiltration connus, mesures déjà prises.

Évaluer les risques pour les droits et libertés des personnes, y compris les conséquences possibles : fraude, usurpation d'identité, discrimination, atteinte à la confidentialité ou préjudice physique.

Alerter le responsable de traitement et le DPO, s'il existe ; le sous-traitant informe le responsable sans délai indu après avoir pris connaissance de la violation.

Documenter la violation et les décisions prises, y compris la décision de ne pas notifier.

2.3. La règle des 72 heures

L'article 33 impose au responsable de traitement de notifier la violation à l'autorité de contrôle compétente — en France, généralement la CNIL — dans les meilleurs délais et, si possible, au plus tard 72 heures après en avoir pris connaissance, sauf si la violation n'est pas susceptible d'engendrer un risque pour les droits et libertés des personnes.

Le délai ne se calcule pas automatiquement à partir du moment où l'attaque a commencé : le point important est le moment où le responsable a pris connaissance de la violation. L'organisation doit cependant détecter et faire remonter rapidement les incidents. Si la notification intervient après 72 heures, les motifs du retard doivent être expliqués.

Si toutes les informations ne sont pas disponibles dans le délai, une notification initiale peut être effectuée puis complétée progressivement. Il ne faut pas attendre d'avoir une enquête parfaite si une notification est nécessaire.

2.4. Faut-il informer les personnes ?

Niveau de risque	Documentation interne	Notification à la CNIL	Information des personnes
Aucun risque probable	Oui	Pas nécessaire au titre de l'art. 33	Pas nécessaire au titre de l'art. 34
Risque pour les droits et libertés	Oui	Oui, au plus tard dans les 72 h si possible	Pas automatiquement requise
Risque élevé	Oui	Oui	Oui, dans les meilleurs délais, sauf exception légale

L'information des personnes doit être claire et accessible. Elle décrit la nature de la violation, fournit un point de contact, explique les conséquences probables et les mesures prises ou proposées pour remédier à la violation et en atténuer les effets.

L'article 34 prévoit des exceptions, notamment lorsque des mesures de protection appropriées rendent les données incompréhensibles aux personnes non autorisées (par exemple, dans certaines conditions, un chiffrement robuste), lorsque des mesures ultérieures ont supprimé le risque élevé, ou lorsque l'information individuelle exigerait des efforts disproportionnés et qu'une communication publique ou mesure similaire assure une information tout aussi efficace.

2.5. Schéma décisionnel à mémoriser

Étape	Question / action
1. Violation ?	Y a-t-il destruction, perte, altération, divulgation ou accès non autorisé à des données personnelles ?
2. Documenter	Consigner les faits, effets, mesures et décisions dans tous les cas.
3. Évaluer le risque	La violation est-elle susceptible d'engendrer un risque pour les droits et libertés ?

Étape	Question / action
4. Risque absent	Pas de notification CNIL au titre de l'article 33, mais documentation obligatoire.
5. Risque présent	Notifier la CNIL dans les meilleurs délais et si possible sous 72 h.
6. Risque élevé	Informer aussi les personnes concernées dans les meilleurs délais, sauf exception prévue par le RGPD.

Partie 3 — Contenu d'une fiche de notification (15 min)

Une notification utile doit donner à l'autorité une compréhension claire de l'incident, de son ampleur, de ses conséquences et des mesures de réduction du risque. L'article 33(3) prévoit notamment :

- La nature de la violation, y compris si possible les catégories et le nombre approximatif de personnes concernées et d'enregistrements concernés.
- Le nom et les coordonnées du DPO ou d'un autre point de contact.
- Les conséquences probables de la violation.
- Les mesures prises ou proposées pour remédier à la violation et, le cas échéant, atténuer ses effets.
- Si tous les éléments ne sont pas disponibles, les fournir par étapes sans retard indu.

Une fiche interne peut comporter davantage d'informations utiles à l'enquête : chronologie, systèmes touchés, origine, journaux conservés, actions de confinement, décision motivée sur le risque et preuves des communications. La fiche interne ne remplace pas nécessairement le formulaire officiel de notification de la CNIL.

Livrable — Fiche type de notification de violation

Modèle pédagogique à compléter. Utiliser « inconnu à ce stade » lorsque l'information n'est pas confirmée ; distinguer les faits établis des hypothèses. Ne pas inventer de chiffres ou de causes.

A. Identification et suivi

Champ	À compléter
Référence interne de l'incident	[ID incident]
Organisme responsable de traitement	[Nom, coordonnées]
Personne chargée du suivi / DPO	[Nom ou fonction, courriel, téléphone]
Date et heure de détection	[Date, heure, fuseau horaire]
Date et heure de prise de connaissance par le responsable	[Date, heure, justification si incertaine]
Date et heure de notification à la CNIL, si applicable	[Date, heure]
Statut	[En cours / contenu / remédiation / clôturé]

B. Description de la violation

Champ	À compléter
Type	[Confidentialité / intégrité / disponibilité / combinaison]
Résumé factuel	[Que s'est-il passé ? Où ? Comment a-t-on découvert l'incident ?]
Chronologie	[Début estimé, détection, escalade, confinement, actions successives]
Systèmes et services concernés	[Applications, serveurs, postes, messagerie, papier, prestataire]
Cause	[Confirmée / probable / inconnue à ce stade ; préciser les preuves]
Accès ou exfiltration	[Confirmé / non confirmé / en cours d'investigation ; éléments disponibles]

C. Données et personnes concernées

Champ	À compléter
Catégories de personnes	[Clients, salariés, candidats, patients, élèves, etc.]
Nombre approximatif de personnes	[Nombre ou estimation justifiée ; préciser si inconnu]
Catégories de données	[Identité, coordonnées, données financières, santé, identifiants, journaux, etc.]
Nombre approximatif d'enregistrements	[Nombre ou estimation ; distinguer personnes et enregistrements]
Données sensibles ou à risque particulier	[Oui / non / à confirmer ; préciser sans exposer inutilement les données]
Mesures de protection préexistantes	[Chiffrement, contrôle d'accès, pseudonymisation, sauvegardes, etc.]

D. Évaluation des risques

Question	Analyse / justification
Conséquences possibles	[Fraude, hameçonnage ciblé, usurpation d'identité, atteinte à la vie privée, indisponibilité, etc.]
Probabilité et gravité	[Éléments pris en compte ; incertitudes restantes]
Risque pour les droits et libertés ?	[Non probable / oui / en cours d'évaluation — justifier]
Risque élevé ?	[Oui / non / en cours d'évaluation — justifier]
Décision de notification CNIL	[Oui / non ; motif et décideur]
Décision d'informer les personnes	[Oui / non ; motif et décideur ; exception éventuelle analysée]

E. Mesures de réponse

Mesure	État / date / responsable
Confinement et suppression de l'exposition	[Mesure, date, responsable]
Réinitialisation des identifiants / révocation des accès	[Mesure, date, responsable]
Préservation des preuves et journaux	[Mesure, date, responsable]
Analyse technique et recherche de cause racine	[En cours / résultat]
Remédiation et réduction des risques	[Mesure, échéance, responsable]
Information / assistance des personnes	[Canal, date, contenu, recommandations pratiques]
Actions correctives à long terme	[Contrôles, procédures, formation, tests]

F. Notification et compléments

Champ	À compléter
Résumé à communiquer à la CNIL	[Résumé factuel, nature, ampleur, conséquences et mesures]
Informations encore manquantes	[Liste des éléments en attente et moyens pour les obtenir]
Plan de notification par étapes	[Échéances et responsable des compléments]
Motifs d'un éventuel dépassement des 72 h	[Explication factuelle]
Pièces et preuves associées	[Chronologie, journaux, analyses, copies de communications, décisions]
Validation interne	[Nom/fonction, date, décision]

Rappel : la notification à la CNIL et l'information des personnes sont deux décisions distinctes. Une notification CNIL est requise lorsqu'il existe un risque pour les droits et libertés, sauf si ce risque est improbable. L'information individuelle est requise lorsque le risque est élevé, sous réserve des exceptions de l'article 34.

Cas pratiques — format examen

Cas 1 — Courriel envoyé au mauvais destinataire

Un salarié envoie par erreur un fichier de 150 clients à une adresse externe. Le fichier contient noms, adresses électroniques et historique de commandes. Le destinataire affirme l'avoir supprimé, mais aucune preuve technique n'est disponible.

Questions : s'agit-il d'une violation ? Quelles actions immédiates ? Notification CNIL automatique ?

Correction : oui, il s'agit au minimum d'une divulgation non autorisée de données personnelles. Il faut contacter le destinataire, demander la suppression et la confirmation, conserver les preuves, déterminer les données et personnes concernées, évaluer les conséquences et documenter l'incident. La notification CNIL n'est pas automatique : elle dépend du risque pour les droits et libertés. Si un risque existe, notifier dans le délai applicable ; informer les personnes si le risque est élevé.

Cas 2 — Ransomware et données chiffrées

Un ransomware rend indisponible un système RH. L'organisation ignore encore si des données ont été exfiltrées. Les sauvegardes sont en cours de vérification.

Correction : la perte d'accès ou l'indisponibilité de données personnelles peut constituer une violation même sans exfiltration confirmée. Isoler les systèmes, préserver les journaux, évaluer l'intégrité des sauvegardes, identifier les données et les personnes concernées, documenter les faits. Ne pas attendre la confirmation d'une exfiltration pour évaluer l'obligation de notification. Si le risque ne peut être exclu et qu'une notification est requise, fournir les éléments disponibles puis compléter.

Cas 3 — Base exposée mais chiffrée

Une base contenant des données personnelles a été exposée. L'organisation affirme que le chiffrement était activé, mais ne sait pas si les clés étaient également accessibles.

Correction : le chiffrement peut réduire le risque, mais ne suffit pas à conclure sans analyse. Vérifier l'algorithme, la mise en œuvre, la gestion et l'exposition des clés, les données en clair présentes ailleurs et les journaux d'accès. Documenter la décision de notifier ou non. L'exception à l'information des personnes n'est applicable que si les conditions du RGPD sont réellement remplies.

Cas 4 — Demande d'accès

Une personne demande une copie de toutes ses données personnelles et des informations sur leur utilisation. Le service client répond qu'il ne peut transmettre que le profil visible dans l'application.

Correction : la demande doit être analysée au regard de l'article 15. Il faut rechercher les données personnelles pertinentes dans les systèmes concernés et fournir une copie ainsi que les informations prévues par le RGPD, tout en protégeant les droits et libertés d'autrui. Le délai général est d'un mois, avec prolongation possible dans les conditions prévues.

Mini-évaluation (10 questions)

1. Qui détermine les finalités et les moyens essentiels ?

Réponse : Le responsable de traitement.

2. Le DPO décide-t-il seul de la conformité de l'organisme ?

Réponse : Non. Il conseille et contrôle avec indépendance ; la responsabilité du traitement reste portée par les acteurs auxquels le RGPD l'attribue.

3. Le registre est-il une liste de logiciels ?

Réponse : Non. Il recense les activités de traitement par finalité.

4. Le consentement est-il toujours obligatoire ?

Réponse : Non. Il existe six bases légales à l'article 6.

5. Une case précochée vaut-elle consentement ?

Réponse : Non.

6. Le droit à l'effacement est-il absolu ?

Réponse : Non. Des exceptions peuvent s’appliquer, notamment certaines obligations légales.

7. Toute violation doit-elle être notifiée à la CNIL ?

Réponse : Non. Elle doit toujours être documentée ; la notification dépend du risque, avec l’exception prévue lorsque le risque est improbable.

8. Quel est le délai de notification prévu à l’article 33 ?

Réponse : Dans les meilleurs délais et si possible au plus tard 72 heures après la prise de connaissance par le responsable.

9. Quand informer les personnes ?

Réponse : Lorsque la violation est susceptible d’engendrer un risque élevé pour leurs droits et libertés, sous réserve des exceptions prévues.

10. Que faire si les informations sont incomplètes à 72 heures ?

Réponse : Notifier les éléments disponibles si une notification est requise et compléter par étapes sans retard indu.

Fiche mémo — les erreurs fréquentes à l’examen

- Confondre responsable de traitement et sous-traitant.
- Dire que le DPO porte seul la responsabilité de conformité.
- Choisir le consentement par réflexe, sans examiner les autres bases légales.
- Croire que le registre doit être organisé par logiciel plutôt que par finalité.
- Confondre violation de données et cyberattaque : une erreur humaine peut suffire.
- Dire que toutes les violations doivent être notifiées à la CNIL sous 72 h : le risque doit être évalué et la violation documentée dans tous les cas.
- Confondre notification à la CNIL et information des personnes : l’information individuelle concerne en principe les violations présentant un risque élevé.
- Attendre la fin de l’enquête avant de signaler l’incident ou inventer des éléments manquants.
- Oublier de documenter la justification d’une décision de ne pas notifier.

Références officielles pour approfondir

1. Règlement général sur la protection des données (RGPD), texte officiel en français : https://eur-lex.europa.eu/eli/reg/2016/679/oj/fra

2. CNIL — Registre des activités de traitement : https://www.cnil.fr/fr/definition/registre-des-activites-de-traitement

3. CNIL — Consentement : https://www.cnil.fr/les-bases-legales/consentement

4. CNIL — Violations de données personnelles : https://cnil.fr/fr/violations-de-donnees-personnelles-les-regles-suivre

Articles à retenir : RGPD art. 4 (définitions), 5 (principes), 6–7 (base légale et consentement), 12–22 (droits), 28 (sous-traitance), 30 (registre), 32 (sécurité), 33–34 (violations).

LEXIQUE DES TERMES ESSENTIELS

Définitions synthétiques des notions clés abordées dans les séances 4 et 5

Donnée personnelle (art. 4)

Toute information se rapportant à une personne physique identifiée ou identifiable (nom, adresse e-mail nominative, identifiant de compte, certaines adresses IP, données de localisation, données de santé, etc.).

Traitement

Toute opération ou ensemble d'opérations appliquées à des données personnelles : collecte, enregistrement, classement, consultation, transmission, modification, conservation ou suppression. Peut être numérique, papier ou hybride.

Responsable de traitement

Personne physique ou morale, autorité publique, service ou autre organisme qui détermine les finalités (pourquoi) et les moyens essentiels (comment) du traitement.

Sous-traitant

Personne ou organisme qui traite des données personnelles pour le compte du responsable de traitement, selon ses instructions documentées (ex. : hébergeur, prestataire RH).

Responsables conjoints

Deux ou plusieurs responsables qui déterminent ensemble les finalités et les moyens essentiels d'un même traitement.

DPO (Délégué à la protection des données)

Personne désignée pour informer, conseiller, sensibiliser et contrôler la conformité au RGPD. Sert de point de contact avec l'autorité de contrôle (CNIL). Ne remplace pas la direction et n'endosse pas automatiquement la responsabilité juridique.

Registre des activités de traitement (art. 30)

Document structuré recensant les traitements mis en œuvre (finalités, catégories de données et de personnes, destinataires, durées, mesures de sécurité, etc.). Outil de pilotage et de preuve de conformité, organisé par finalité et non par logiciel.

Base légale (art. 6)

Fondement juridique qui rend un traitement licite. Les six bases sont : consentement, contrat / mesures précontractuelles, obligation légale, intérêts vitaux, mission d'intérêt public / autorité publique, intérêts légitimes.

Consentement

Manifestation de volonté libre, spécifique, éclairée et univoque par laquelle la personne accepte le traitement de ses données pour une ou plusieurs finalités déterminées. Doit pouvoir être prouvé et retiré aussi facilement qu'il a été donné.

Droit d'accès (art. 15)

Droit de la personne d'obtenir la confirmation que des données la concernant sont traitées, d'en recevoir une copie et d'obtenir des informations sur le traitement.

Droit de rectification (art. 16)

Droit d'obtenir la correction de données inexactes ou le complément de données incomplètes.

Droit à l'effacement / droit à l'oubli (art. 17)

Droit d'obtenir l'effacement des données dans les cas prévus (données plus nécessaires, retrait du consentement sans autre base, etc.). Ce droit n'est pas absolu (exceptions : obligations légales, liberté d'expression, intérêt public, défense de droits en justice…).

Droit à la portabilité (art. 20)

Droit de recevoir les données fournies par la personne dans un format structuré, couramment utilisé et lisible par machine, et de les transmettre à un autre responsable. S'applique notamment aux traitements automatisés fondés sur le consentement ou le contrat.

Violation de données personnelles (art. 4.12)

Violation de la sécurité entraînant, de manière accidentelle ou illicite, la destruction, la perte, l'altération, la divulgation non autorisée ou l'accès non autorisé à des données personnelles. Peut concerner la confidentialité, l'intégrité ou la disponibilité.

Notification à la CNIL (art. 33)

Obligation pour le responsable de traitement de notifier une violation à l'autorité de contrôle (CNIL en France) dans les meilleurs délais et, si possible, au plus tard 72 heures après en avoir pris connaissance, sauf si la violation n'est pas susceptible d'engendrer un risque pour les droits et libertés des personnes.

Information des personnes (art. 34)

Obligation d'informer individuellement les personnes concernées lorsque la violation est susceptible d'engendrer un risque élevé pour leurs droits et libertés, sous réserve des exceptions prévues (chiffrement robuste, mesures ultérieures ayant éliminé le risque élevé, efforts disproportionnés…).

CNIL

Commission Nationale de l'Informatique et des Libertés — autorité de contrôle française chargée de veiller au respect du RGPD et de la loi Informatique et Libertés.

FAQ — QUESTIONS FRÉQUENTES

Réponses synthétiques aux questions les plus courantes sur les obligations, droits et violations RGPD

Q. Qui détermine les finalités et les moyens essentiels d'un traitement ?

R. Le responsable de traitement. C'est le critère principal qui le distingue du sous-traitant.

Q. Le DPO décide-t-il seul de la conformité de l'organisme ?

R. Non. Le DPO conseille, sensibilise et contrôle avec indépendance. La responsabilité du traitement reste portée par le responsable de traitement (et éventuellement les responsables conjoints).

Q. Le registre des activités de traitement est-il une simple liste de logiciels ?

R. Non. Il doit recenser les activités de traitement par finalité. Un même logiciel peut servir à plusieurs traitements, et inversement.

Q. Le consentement est-il toujours obligatoire pour traiter des données personnelles ?

R. Non. Le RGPD prévoit six bases légales (art. 6). Le consentement n'est qu'une base parmi d'autres. Il faut choisir celle qui correspond réellement à la finalité.

Q. Une case précochée « J'accepte » constitue-t-elle un consentement valide ?

R. Non. Le consentement doit être univoque : une action positive claire est requise. Le silence, l'inaction ou une case précochée ne suffisent pas.

Q. Le droit à l'effacement (droit à l'oubli) est-il absolu ?

R. Non. Des exceptions existent, notamment lorsque le traitement est nécessaire au respect d'une obligation légale, à l'exercice du droit à la liberté d'expression, pour des motifs d'intérêt public ou pour la constatation, l'exercice ou la défense de droits en justice.

Q. Toute violation de données doit-elle être notifiée à la CNIL sous 72 heures ?

R. Non. Toute violation doit être documentée. La notification à la CNIL n'est obligatoire que si la violation est susceptible d'engendrer un risque pour les droits et libertés des personnes. Le délai de 72 heures court à partir de la prise de connaissance par le responsable.

Q. Quand faut-il informer les personnes concernées d'une violation ?

R. Lorsque la violation est susceptible d'engendrer un risque élevé pour leurs droits et libertés, sous réserve des exceptions de l'article 34 (ex. : données rendues incompréhensibles par un chiffrement robuste, mesures ultérieures ayant éliminé le risque élevé).

Q. Que faire si toutes les informations ne sont pas disponibles dans le délai de 72 heures ?

R. Notifier les éléments disponibles si une notification est requise, puis compléter progressivement sans retard indu. Il ne faut pas attendre d'avoir une enquête parfaite.

Q. Un sous-traitant peut-il devenir responsable de traitement ?

R. Oui, s'il détermine lui-même les finalités et les moyens essentiels du traitement (au-delà des instructions du responsable). Dans ce cas, il peut être qualifié de responsable (ou de responsable conjoint).

Q. Comment calculer le début du délai de 72 heures ?

R. Le point de départ est le moment où le responsable de traitement a pris connaissance de la violation (et non le moment où l'attaque a commencé). L'organisation doit néanmoins détecter et faire remonter rapidement les incidents.

Q. Faut-il toujours vérifier l'identité avant de répondre à une demande de droits ?

R. Une vérification proportionnée peut être demandée en cas de doute raisonnable sur l'identité. Elle ne doit pas être systématique ni excessive.

Q. Quelle est la différence entre notification à la CNIL et information des personnes ?

R. Ce sont deux décisions distinctes. La notification CNIL dépend de l'existence d'un risque (art. 33). L'information individuelle des personnes dépend de l'existence d'un risque élevé (art. 34).

Q. Une erreur humaine (envoi d’un fichier au mauvais destinataire) peut-elle constituer une violation ?

R. Oui. Une violation n’implique pas nécessairement un piratage. Une erreur humaine, une perte de support ou un envoi au mauvais destinataire peuvent constituer une violation de confidentialité.

Ce FAQ complète le support pédagogique sans modifier le contenu original des séances 4 et 5. Pour toute situation réelle, se référer aux textes applicables et aux recommandations à jour de la CNIL.